Ex 12: Security Features and Governance in Zoho Creator

Topic: Patient Appointment Booking Form

V Vijay Prakash
241401128

1. Aim

To study the security and governance features of Zoho Creator and plan how they apply to the Patient Appointment Booking application, covering account protection, role-based access, data permissions, safe Deluge scripting, managed connections, controlled releases and audit review. Because the application holds patients' names, phone numbers and email addresses, access to it needs to be limited and traceable.

2. Procedure

Step	Activity
1. Identify sensitive data	Review the booking form and report to list the personal fields: patient name, phone, email, and the doctor and appointment details.
2. Protect accounts	Use strong passwords and two-factor sign-in for everyone who can open the application; use single sign-on where the organisation provides it.
3. Define roles	Set up Admin, Doctor, Front Desk and Patient profiles, giving each only the access its work needs (least privilege).
4. Set access rules	Combine profile permissions on forms and reports with record-level criteria so users see only the bookings relevant to them.
5. Secure scripts and connections	Validate input in Deluge before saving, and keep service credentials inside managed connections instead of writing them in scripts.
6. Govern changes	Test changes before they reach live users, review who has access at regular intervals, and check the audit records.

241401128

Table 1: Planned Security and Governance Steps

3. Output

3.1 Layers of Protection

Layer	What It Covers
Account and sign-in	Passwords, two-factor sign-in, single sign-on and session handling.
Application access	Profiles and roles decide which forms, reports and pages a user can open.
Data access	Permissions and criteria limit which records and fields a user can see or change.
Logic and integrations	Input validation in scripts, and connections that keep credentials out of code.
Governance and audit	Controlled releases, review of changes and access, and audit logs.

Table 2: Security Layers for the Booking Application

These layers back each other up: if one control is missed, the others still limit how much can be exposed.

3.2 Proposed Permission Matrix

The matrix below is a proposed design; the actual settings should be checked against the profiles configured in the application.

Area	Admin	Doctor	Front Desk	Patient
Booking records	Full control	View own bookings	Create, view, edit	Own bookings only
Contact details (phone, email)	View, edit	View	View, edit	Own details
Reports and exports	All reports	Own schedule	Daily schedule	No access
Workflows and scripts	Manage	No access	No access	No access
Users and connections	Manage	No access	No access	No access

Table 3: Proposed Role-Based Access

3.3 How an Access Request Is Checked

Check	If Allowed	If Denied
Sign-in	The user's assigned profile is identified.	Access is refused and sign-in is requested.
Profile permission	The requested form or report opens.	Access is refused if the permission is missing.
Record and field criteria	Only permitted records and fields are shown.	Visibility is restricted or the action is blocked.
Audit	Relevant actions are logged for review.	Unusual or repeated failures are reviewed.

24401128

Table 4: Access-Control Checks

3.4 Secure Scripting and Connections

The application's own Validate appointment workflow already follows the principle of checking data before it is saved: it cancels the submission with an alert when the appointment date is in the past or when the chosen doctor, date and time slot are already taken. In the same way, any script that talks to another service, such as the CRM integration in Ex 7, should use a named connection and keep tokens and secrets out of the script text.

3.5 Risks and Controls

Risk	Example	Control
Unauthorised access	A former staff member can still open patient data.	Remove access promptly and use sign-in safeguards.
Excess privilege	A user can export or delete more records than needed.	Apply least privilege and separate permissions.
Data leakage	A report containing contact details is shared publicly.	Review sharing settings and avoid public links.
Insecure scripts	Missing validation or a token written into code.	Validate input and use managed connections.
Uncontrolled change	A live edit breaks the booking form.	Test changes first and approve before release.
Poor traceability	A change cannot be traced to anyone.	Review audit trails and logs.

Table 5: Main Risks and Their Controls

3.6 Administration Checklist

Area	Routine Task	Frequency
Users	Assign the right profile; remove people who have left.	When people change
Permissions	Review profile permissions and export rights.	Quarterly
Sign-in	Confirm two-factor or single sign-on settings.	Quarterly
Connections	Limit each connection to the users and apps that need it.	Quarterly
Changes	Test before publishing to live users.	Every release
Audit and backup	Review unusual activity and confirm backups can be restored.	Monthly

Table 6: Administration Routine

4. Result

A security and governance plan was prepared for the Patient Appointment Booking application, covering sign-in protection, role-based access, record-level permissions, safe scripting, managed connections, controlled changes, audit review and routine administration. The settings are presented as a proposed design and should be verified in the live application before being relied on.

241401128